FACULTAD DE DEFENSA NACIONAL — FADENA

LICENCIATURA EN CIBERDEFENSA | Tecnología Operativa 2026

UNIDAD 3: SISTEMAS DE SUPERVISIÓN Y SECTORES CRÍTICOS

AP N°12

ACTIVIDAD PRÁCTICA

Análisis Forense de Tráfico Modbus TCP

Identificación de Maestro No Autorizado y Escritura Maliciosa de Registros

Documento de Cátedra N°12 alineado — Modbus: Función Codes y Perfil de Seguridad

Tiempo estimado	90–120 minutos	**Dificultad**	Intermedia
Herramienta principal	CloudShark (web, sin instalación)	**Recurso adicional**	Wireshark (opcional, local)
Modalidad	Individual, asincrónica	**Entrega**	Captura de pantalla + respuestas escritas
Archivo de trabajo	planta_norte_incident_20260304.pcap (provisto por la cátedra en Moodle)	**Documento alineado**	Doc. de Cátedra N°12

ESCENARIO DEL INCIDENTE

El equipo de Ciberdefensa recibe el siguiente informe:

Planta Norte es una distribuidora de agua potable ficticia de zona metropolitana. Durante el turno nocturno del 4 de marzo de 2026, el sistema SCADA registró alarmas por valores fuera de rango en variables de proceso asociadas al grupo de bombeo principal. El operador de turno no realizó ninguna modificación de parámetros en ese período. El jefe de planta activó el protocolo de respuesta a incidentes y solicitó al equipo de Ciberdefensa que analice el archivo PCAP capturado automáticamente por el sniffer de red instalado en el switch de la red de campo.

TOPOLOGÍA DE RED (según inventario de activos):

IP	Rol	Descripción
192.168.10.5	MTU (master)	Servidor SCADA/MTU — único master autorizado en la red Modbus de la planta
192.168.10.21	PLC-01 (slave)	Controlador del grupo de bombeo principal — salida al sistema de distribución
192.168.10.22	PLC-02 (slave)	Controlador del grupo de bombeo secundario
192.168.10.45	? (no registrada)	IP no registrada en el inventario de activos — su presencia ya es una anomalía

El archivo PCAP **planta_norte_incident_20260304.pcap** cubre la ventana horaria 01:45:00 – 02:30:00 del mismo día. Tu tarea como analista es reconstruir la secuencia de eventos, identificar el tipo de ataque y determinar qué vulnerabilidad estructural de Modbus lo habilitó.

OBJETIVOS DE APRENDIZAJE

Al completar esta actividad, el alumno será capaz de:

- Decodificar una trama Modbus RTU byte a byte, identificando cada campo de la ADU.
- Interpretar tráfico Modbus TCP en CloudShark utilizando filtros de visualización.
- Identificar la presencia de un master no autorizado y reconstruir su secuencia de reconocimiento.
- Analizar una operación de escritura FC16 sobre Holding Registers e interpretar su impacto en el proceso físico.
- Vincular las vulnerabilidades estructurales de Modbus (Sección 6 del Doc. N°12) con un ataque real documentado en PCAP.
- Proponer contramedidas de red concretas que habrían prevenido o detectado el incidente.

INSTRUCCIONES GENERALES

1. Descargar el archivo PCAP desde la sección AP N°12 en Moodle antes de comenzar.
2. Registrar una cuenta gratuita en CloudShark (https://www.cloudshark.org) si aún no se dispone de una. Alternativamente, usar Wireshark instalado localmente.
3. Completar las fases en el orden indicado: primero Predecir (sin PCAP), luego Verificar (con PCAP), luego Comprender.
4. Las capturas de pantalla deben mostrar claramente el filtro aplicado y los resultados; incluir la URL de CloudShark o el nombre de la captura.
5. Redactar las respuestas en los espacios provistos. Las respuestas de análisis (Fase 3) deben ser fundamentadas: citar el campo específico del Doc. N°12 que respalda cada afirmación.
6. No compartir ni discutir los hallazgos del PCAP con compañeros antes de completar la Fase 1 (Predecir).

FASE 1 — PREDECIR (completar ANTES de abrir el archivo PCAP)

PROPÓSITO

Activar el conocimiento previo y formular predicciones antes del análisis. Completar esta fase sin ver el PCAP permite contrastar lo que se espera con lo que realmente contiene la captura, ejercitando el razonamiento analítico que caracteriza al analista forense.

Tarea 1.1 — Decodificación de trama Modbus RTU

La siguiente trama fue capturada en un bus RS-485 de la red de campo de Planta Norte. Decodificar cada byte completando la tabla de análisis. Los campos Color azul requieren cálculo o interpretación; los demás son lectura directa.

01 10 00 60 00 03 06 00 0A 00 14 00 1E 55 BC

Trama Modbus RTU capturada en bus RS-485 — 15 bytes

Bytes (hex)	Campo	Dec / Nombre	Descripción / Análisis
01	Dirección del esclavo		
10	Function Code		Indicar nombre completo del FC y la tabla de datos afectada
00 60	Dirección de inicio		¿Qué registro es el primero afectado?
00 03	Cantidad de registros		
06	Byte Count		Verificar: Qty × 2 = Byte Count
00 0A	Valor — Registro 0x0060		¿Posible parámetro de proceso?
00 14	Valor — Registro 0x0061		
00 1E	Valor — Registro 0x0062		
55 BC	Verificación de integridad	CRC-16	¿Autentica al emisor? ¿Por qué sí / no?

Justificar el impacto de seguridad de esta trama si fue enviada por un master no autorizado. Indicar a qué tipo de tabla de datos afecta y qué consecuencia física podría tener sobre el proceso.

Respuesta:

Tarea 1.2 — Predicciones previas al análisis

Responder ANTES de abrir el PCAP. Las predicciones incorrectas son tan valiosas como las correctas: permiten identificar los supuestos de diseño que el protocolo rompe.

a) En una red industrial correctamente configurada, ¿cuántas IPs distintas deberían aparecer enviando tráfico Modbus al puerto 502 de los PLCs? Justificar.

Respuesta:

b) ¿Qué function codes esperarías ver predominantemente en el tráfico del MTU legítimo durante la operación normal? ¿Por qué el MTU no debería generar tráfico FC05, FC06, FC15 o FC16 en condiciones normales?

Respuesta:

c) Si un atacante sigue la secuencia FC43 → FC01 → FC02 → FC03 → FC04 → FC16, ¿qué metodología describe esta secuencia? Nombrar cada paso con el objetivo que persigue el atacante.

Respuesta:

FASE 2 — VERIFICAR (análisis del archivo PCAP en CloudShark)

CONFIGURACIÓN INICIAL (completar una sola vez)

7. Descargar el archivo planta_norte_incident_20260304.pcap desde Moodle (sección AP N°12).
8. Ingresar a https://www.cloudshark.org. Crear una cuenta gratuita si no se dispone de una (el registro requiere solo dirección de correo).
9. Hacer clic en "Upload" y seleccionar el archivo PCAP descargado. CloudShark asignará una URL única a la captura.
10. Verificar que el panel "Packet List" muestre paquetes con la columna Protocol = "Modbus/TCP" para los intercambios sobre puerto 502. Esto confirma que el disector de Modbus está activo.
11. Incluir en la entrega la URL de CloudShark de tu captura (formato: cloudshark.org/captures/xxxxxxxx).

ETAPA A — Inventario inicial del tráfico capturado

Aplicar filtro:

modbus

a) ¿Cuántos paquetes resultan del filtro? Indicar el número total (requests + responses).

Respuesta:

b) Observar la columna "Source" de los paquetes con Protocol = Modbus/TCP. Listar TODAS las IPs que aparecen como origen de requests Modbus (dport = 502). ¿Cuántas IPs distintas envían tráfico al puerto 502?

Respuesta:

c) Aplicar filtro tcp.dport == 502 and tcp.flags.syn == 1. ¿Cuántas IPs distintas intentaron conectarse al puerto Modbus? Listarlas.

Respuesta:

d) Completar la tabla de inventario a partir del análisis visual del tráfico:

IP Origen	Function Codes observados	Destino(s)	Cantidad aprox. de requests
192.168.10.5			
192.168.10.45			

ETAPA B — Aislamiento de operaciones de escritura

Aplicar filtro:

modbus.func_code == 16

a) ¿Cuántos paquetes muestra el filtro modbus.func_code == 16? ¿Cuál es el origen (IP) del paquete de REQUEST?

Respuesta:

b) Expandir el árbol de protocolo del paquete de request FC16 en el panel de detalles. Identificar e indicar: (1) la dirección de inicio (Start Reference), (2) la cantidad de registros (Word Count), (3) los seis valores escritos en hexadecimal y su equivalente decimal.

Respuesta:

c) Comparar la IP origen de los paquetes FC16 con la IP del MTU legítimo (192.168.10.5). ¿Coincide? ¿Qué implicancia tiene para la seguridad?

Respuesta:

Aplicar filtro adicional:

modbus.func_code >= 5

d) El filtro modbus.func_code >= 5 muestra los FC con código numérico mayor o igual a 5. ¿Qué function codes aparecen ahora además de FC16? ¿Alguno de ellos es de escritura? ¿Cómo explicarías que un FC de identificación de dispositivo tenga un código numérico tan alto?

Respuesta:

ETAPA C — Reconstrucción de la secuencia del atacante

Aplicar filtro:

ip.src == 192.168.10.45

Este filtro muestra TODOS los paquetes enviados por la IP no autorizada. Ordenar por columna Time (creciente) para ver la secuencia cronológica.

a) Completar la siguiente tabla cronológica con los paquetes de REQUEST del atacante (incluir solo los que tienen dport = 502):

Hora (HH:MM:SS)	FC (hex + nombre)	Parámetros principales	¿Qué busca conocer el atacante con este FC?

b) Expandir la response del paquete FC43. ¿Qué información de fabricante y modelo retorna el dispositivo? Explicar cómo un adversario usa esa información en la fase siguiente al reconocimiento.

Respuesta:

c) Calcular el intervalo en segundos entre el primer paquete de 192.168.10.45 y el paquete FC16 de ataque. ¿Qué inferencia se puede hacer sobre el nivel de preparación del atacante?

Respuesta:

d) Comparar los valores leídos por el atacante con FC03 (Etapa C, fila 4 de la tabla) con los valores que el MTU leerá con FC03 inmediatamente después del ataque. ¿Qué diferencia hay y qué significa para el proceso físico?

Respuesta:

FASE 3 — COMPRENDER (síntesis analítica y propuesta de contramedidas)

Las preguntas de esta fase requieren argumentación fundamentada. Cada respuesta debe citar la sección específica del Doc. de Cátedra N°12 que respalda el análisis.

1. ¿Cuál de las cinco vulnerabilidades estructurales de Modbus (Doc. N°12, Sección 6) habilitó directamente que la IP 192.168.10.45 pudiera enviar un FC16 al PLC-01 sin ser rechazada? Citar textualmente el nombre de la vulnerabilidad y explicar por qué esta trama fue aceptada.

Respuesta:

2. Diseñar una regla de firewall industrial con DPI de Modbus que habría bloqueado el ataque. Expresarla en formato: [ORIGEN] [DESTINO] [FC] [ACCIÓN]. ¿Qué funcionalidad del firewall industrial (respecto a un firewall IP tradicional) hace posible esta regla?

Respuesta:

3. Si el atacante hubiera enviado solamente FC03 (lectura de holding registers) en lugar de FC16, ¿habría causado daño al proceso físico? ¿Habría sido igualmente un incidente de seguridad? Fundamentar.

Respuesta:

4. Las alarmas del SCADA se activaron aproximadamente 17 segundos después del paquete FC16 (02:17:43 → 02:18:00 primera lectura). ¿Qué revela ese intervalo sobre el tiempo de respuesta del proceso físico? ¿Qué rol cumpliría un IDS OT respecto a ese mismo intervalo si estuviera desplegado en el switch?

Respuesta:

5. La Sección 6 del Doc. N°12 menciona el 'Registro externo mediante proxy Modbus o IDS OT' como contramedida a la vulnerabilidad 'Sin registro ni auditoría nativa'. Teniendo en cuenta que el PCAP fue capturado por un sniffer en el switch, ¿qué diferencia existe entre un sniffer pasivo y un proxy Modbus en cuanto a su capacidad de respuesta al incidente? ¿Cuál de los dos habría sido más efectivo en este caso y por qué?

Respuesta:

CRITERIOS DE ENTREGA

Componente	Puntaje	Descripción
Fase 1 — Predecir	20 pts	T1.1: tabla de decodificación RTU completa (10 pts). T1.2: tres predicciones justificadas (10 pts).
Fase 2 — Verificar (A)	20 pts	Inventario completo con capturas de pantalla. URL de CloudShark obligatoria.
Fase 2 — Verificar (B+C)	25 pts	Análisis de FC16 con valores exactos (10 pts). Tabla cronológica del atacante completa con interpretación de cada FC (15 pts).
Fase 3 — Comprender	35 pts	Respuestas analíticas (5 preguntas × 7 pts). Cada respuesta debe referenciar la sección del Doc. N°12 que la fundamenta.
TOTAL	**100 pts**	Subir UNA sola entrega en PDF con capturas de pantalla integradas.